COMPTIA SECURITY+ SY0-701 | DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.6 · Multifactor Authentication

Mestre CyberSec · **Aula 4.6 — Multifactor Authentication** (4:29) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** MFA: 2+-fatores de CATEGORIA DIFERENTE: sabe (senha/PIN); tem (token, celular, FIDO2); é (biometria); sei (location). Senha+PIN não conta (mesma categoria).

💡 Highlights que a prova CompTIA cobra

- MFA: fatores de TIPO DIFERENTE — saber/ter/ser
- Senha + PIN = MESMA categoria ('sabe') — NÃO é MFA
- TOTP: código de 6 dígitos que muda a cada 30s

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'combines something you know with something you have'=proper MFA

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.6 — Multifactor Authentication)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Autenticação Multifator (MFA)
Autenticação que exige dois ou mais fatores de CATEGORIAS DIFERENTES (algo que você sabe, tem, é ou onde você está). Oferece verificação de identidade muito mais forte que fator único.

⚠ ***Armadilha CompTIA:*** *SENHA + PIN = mesma categoria ('sabe') → NÃO é MFA (pegadinha clássica). Se a questão diz 'combines something you know with something you have', isso É MFA verdadeiro.*

• Algo que você sabe
Fator de autenticação baseado em informação memorizada: senha, PIN, respostas de perguntas de segurança ou frase-senha.

⚠ ***Armadilha CompTIA:*** *Password E PIN pertencem ao MESMO fator — usar os dois juntos é single-factor e a prova adora esse trap. Este fator é o mais vulnerável a shoulder surfing, sniffing e social engineering.*

• Algo que você tem
Fator baseado em posse física ou digital: cartão inteligente, token de hardware, app TOTP no celular ou chave de segurança FIDO2.

⚠ ***Armadilha CompTIA:*** *Senhas + qualquer 'have' (token, celular, smart card) = MFA correto. Um código TOTP recebido no celular conta como 'tem'. Combina com 'know' nas perguntas de cenário.*

• Algo que você é
Fator biométrico baseado em características físicas únicas: digital, reconhecimento facial, varredura de íris, varredura de retina ou impressão vocal.

⚠ ***Armadilha CompTIA:*** *Biometria ('are') NÃO é 'have'. Digital + senha = MFA válido. Biometria não pode ser trocada se comprometida e levanta questões de privacidade e volume de dados.*

• Algum lugar onde você está (localização)
Fator de autenticação baseado em localização, usando geolocalização/GPS ou endereço IP para permitir ou negar acesso conforme o local físico do usuário.

⚠ ***Armadilha CompTIA:*** *Questão citando restrição de acesso por país/região/IP → fator 'somewhere you are'. É uma categoria válida para MFA quando combinada com outro fator de categoria diferente.*

• Algo que você faz (comportamento)

Fator baseado em comportamento, analisando padrões pessoais: cadência de digitação, padrão de deslize na tela, jeito de andar ou movimento do mouse.

⚠️ ***Armadilha CompTIA:*** *Padrão de digitação = 'algo que você faz' (comportamento), diferente de 'algo que você é' (biometria estática) e de 'algo que você sabe' (conteúdo da senha). Distinção fina cobrada na prova.*

• Senha Descartável Baseada em Tempo (TOTP)

Senha de uso único gerada por app ou token a partir de um segredo compartilhado e da hora atual; produz um código de 6 dígitos que muda a cada 30 segundos.

⚠️ ***Armadilha CompTIA:*** *'Código de 6 dígitos que expira a cada 30 s' = TOTP. Diferença-chave: HOTP é baseado em contador (válido até ser usado), TOTP é baseado em tempo (expira). TOTP conta como fator 'have'.*

• Chave de Segurança de Hardware (FIDO2)

Autenticador físico (USB/NFC/Bluetooth) que usa os padrões FIDO2/WebAuthn e criptografia de chave pública para fornecer autenticação 'algo que você tem' resistente a phishing.

⚠️ ***Armadilha CompTIA:*** *FIDO2 = fator 'have'. Usa challenge-response assimétrico (não envia segredo/código, por isso resiste a phishing). A prova pode contrapor chave FIDO2 a OTP por SMS ou códigos TOTP.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de software lança uma nova política que exige que os funcionários informem a senha padrão seguida de um PIN de seis dígitos antes que o repositório de código-fonte seja aberto. O diretor de TI anuncia na reunião geral que o repositório agora atende à exigência de conformidade para autenticação multifator. Um analista de segurança que revisa o fluxo de login discorda e pretende registrar uma constatação. Qual é a justificativa tecnicamente mais precisa para a posição do analista?

A) O PIN de seis dígitos é curto demais para ser reconhecido como um segundo fator válido pelas estruturas de conformidade

B) A senha e o PIN pertencem à mesma categoria de fator, de modo que o login continua sendo uma autenticação de fator único

C) Solicitar dois segredos na mesma sessão do navegador impede que o segundo fator seja validado por um servidor separado

D) As exigências de conformidade requerem ao menos uma entrada biométrica para que um login seja contado como multifator

QUESTÃO 2 · CENÁRIO DE EXAME

Uma plataforma de banco online solicita que os clientes informem a senha e, em seguida, um código de seis dígitos que é renovado a cada 30 segundos dentro de um aplicativo autenticador no celular. Durante o treinamento de integração, uma nova analista de fraude pergunta a qual categoria de fator de autenticação esse código rotativo pertence. O que o instrutor deve responder?

A) Algo que você tem, porque o código é gerado por um dispositivo em posse do cliente

B) Algo que você sabe, porque o cliente precisa ler os dígitos e digitá-los manualmente

C) Algo que você é, porque o código está vinculado exclusivamente à identidade do titular da conta

D) Algum lugar em que você está, porque o código só é validado em regiões geográficas registradas

QUESTÃO 3 · CENÁRIO DE EXAME

Invaders conduziram uma campanha de phishing adversary-in-the-middle que capturou as senhas dos funcionários e repassou seus códigos de uso único em tempo real, anulando completamente o segundo fator atual baseado em SMS. O CISO quer um método resistente a phishing para todas as contas privilegiadas e tem orçamento aprovado para hardware. Qual solução melhor atende ao requisito?

A) Aumentar os códigos de uso único por SMS de seis para oito dígitos para dificultar a interceptação automatizada

B) Entregar os códigos de uso único por um aplicativo de mensagens criptografadas em vez de SMS

C) Enviar notificações push de aprovação por toque para os celulares registrados dos funcionários

D) Fornecer chaves de segurança de hardware FIDO2 que verificam criptograficamente a origem do serviço legítimo antes de liberar uma credencial

QUESTÃO 4 · CENÁRIO DE EXAME

A equipe de TI de um hospital configura o portal do prontuário eletrônico para que os clínicos só consigam entrar a partir das redes internas do hospital e das faixas de endereços VPN registradas. Tentativas vindas de hotéis, aeroportos ou endereços IP estrangeiros desconhecidos são negadas mesmo quando o usuário, a senha e o código do app autenticador são fornecidos corretamente. Qual categoria de fator de autenticação o hospital está impondo com essa regra?

A) Algo que você tem

B) Algo que você faz

C) Algum lugar em que você está

D) Algo que você é

QUESTÃO 5 · CENÁRIO DE EXAME

Visitantes de um data center de co-location precisam encostar um smart badge com chip no leitor de entrada e, em seguida, colocar o dedo em um scanner biométrico dentro do mantrap antes que a porta interna seja liberada. Qual combinação de categorias de fatores esse procedimento de entrada em duas etapas impõe?

A) Algo que você sabe e algo que você tem

B) Algo que você tem e algo que você é

C) Algo que você é e algum lugar em que você está

D) Algo que você faz e algo que você sabe

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa de e-commerce está reforçando a segurança de seu console administrativo e precisa escolher um fluxo de login que se qualifique como autenticação multifator genuína. Qual implementação satisfaz esse requisito?

A) Uma frase-senha longa seguida imediatamente de um PIN de conta de quatro dígitos

B) Uma senha mais duas perguntas de verificação pessoal extraídas do perfil de RH do usuário

C) Um PIN numérico combinado com a resposta a uma pergunta de segurança memorável

D) Uma senha combinada com uma leitura ao vivo da íris do administrador

QUESTÃO 7 · CENÁRIO DE EXAME

A equipe de prevenção a fraudes de uma corretora implanta monitoramento contínuo de sessão que cria uma linha de base da cadência de digitação e da dinâmica do mouse de cada trader; quando uma sessão ativa se desvia significativamente dessa base, o sistema exige verificação adicional. Qual categoria de fator de autenticação esse perfil comportamental representa?

A) Algo que você faz

B) Algo que você é

C) Algo que você tem

D) Algum lugar em que você está

QUESTÃO 8 · CENÁRIO DE EXAME

Invasores executaram fraude de SIM swap contra vários funcionários e interceptaram os códigos de uso único por SMS usados nos logins de VPN, embora todos os usuários afetados tivessem digitado corretamente o par senha e código. A liderança deseja manter a verificação em duas etapas, mas eliminar a dependência da operadora de celular. Qual mudança melhor consegue isso?

A) Manter a entrega por SMS, mas estender os códigos de seis para oito dígitos

B) Redirecionar os códigos de uso único para os e-mails corporativos dos funcionários como canal de entrega

C) Substituir os códigos SMS por códigos TOTP gerados por um aplicativo autenticador instalado no celular de cada funcionário

D) Reduzir a janela de expiração dos códigos SMS de dez minutos para sessenta segundos

QUESTÃO 9 · CENÁRIO DE EXAME

Os usuários de uma suíte de produtividade em nuvem habitualmente aprovam as notificações push de MFA sem lê-las, porque várias chegam ao longo do expediente. Atacantes armados com senhas coletadas exploraram esse hábito às 2h da manhã, inundando um usuário com solicitações de aprovação até que um toque acidental concedesse acesso. A equipe de segurança quer um recurso que obrigue os usuários a verificar ativamente qual tentativa estão autorizando. Qual modificação melhor atende a esse objetivo?

A) Estender a janela de expiração das solicitações push de dois para cinco minutos

B) Ativar o number matching, exigindo que o usuário digite o código numérico exibido na tela de login no dispositivo de aprovação

C) Usar links de aprovação entregues por SMS como fallback sempre que a notificação do aplicativo não for respondida

D) Permitir que os usuários registrem o laptop como dispositivo confiável para pular as solicitações push em logins familiares

QUESTÃO 10 · CENÁRIO DE EXAME

Um aeroporto planeja substituir os leitores de badge dos postos de controle de funcionários por uma catraca com reconhecimento facial. O diretor de segurança pergunta ao fornecedor qual métrica de precisão expressa a probabilidade de a triagem admitir erroneamente uma pessoa que não é um funcionário autorizado. Qual métrica deve ser reportada?

A) Taxa de rejeição falsa, porque mede com que frequência um funcionário genuíno é negado

B) Taxa de erro de cruzamento, porque indica o ponto de sensibilidade em que os dois tipos de erro se equilibram

C) Taxa de aceitação falsa, porque mede com que frequência um indivíduo não autorizado recebe acesso incorretamente

D) Tempo de cadastro (enrollment), porque reflete a rapidez com que os rostos da equipe são registrados no sistema

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — A senha e o PIN pertencem à mesma categoria de fator, de modo que o login continua sendo uma autenticação de fator único

A verdadeira autenticação multifator exige credenciais de pelo menos duas CATEGORIAS diferentes: algo que você sabe, algo que você tem, algo que você é, algum lugar em que você está ou algo que você faz. Tanto a senha quanto o PIN se enquadram em 'algo que você sabe'; embora o usuário forneça dois segredos distintos, o login continua sendo de fator único e a exigência de conformidade não é atendida. Para corrigir a constatação, a empresa deve acrescentar uma categoria realmente diferente, como um app TOTP, uma chave de segurança de hardware ou um leitor biométrico.

Questão 2: Alternativa A — Algo que você tem, porque o código é gerado por um dispositivo em posse do cliente

Embora o usuário digite o valor, uma senha de uso único baseada em tempo (TOTP) é produzida por um aplicativo autenticador ou token de hardware em posse do usuário; por isso a CompTIA a classifica como 'algo que você tem'. A categoria é determinada pela forma como a credencial é gerada e vinculada — a posse do dispositivo com a semente — e não pelo ato físico de digitar. É por isso que combinar uma senha (sabe) com um código TOTP (tem) alcança a verdadeira autenticação multifator.

Questão 3: Alternativa D — Fornecer chaves de segurança de hardware FIDO2 que verificam criptograficamente a origem do serviço legítimo antes de liberar uma credencial

As chaves de segurança FIDO2 são resistentes a phishing porque a chave privada nunca sai do dispositivo e a assinatura é vinculada à origem genuína (domínio) registrada no cadastro; um site de phishing via proxy apresenta uma origem diferente, então a chave se recusa a autenticar e o relay adversary-in-the-middle não obtém nada utilizável. Códigos mais longos ou um canal criptografado ainda transmitem um segredo reaproveitável pelo proxy do atacante, e as notificações push de aprovação por toque permanecem expostas a ataques de relay em tempo real e de fadiga.

Questão 4: Alternativa C — Algum lugar em que você está

Restringir o acesso com base na localização de rede, no endereço IP ou por geofencing implementa o fator 'algum lugar em que você está'. O clínico já apresenta um fator de conhecimento (senha) e um fator de posse (app TOTP), mas a política adiciona uma categoria independente — um contexto geográfico ou de rede válido —, o que eleva a força geral da autenticação para além das duas credenciais fornecidas.

Questão 5: Alternativa B — Algo que você tem e algo que você é

O smart badge é uma credencial de posse ('algo que você tem') e a leitura da impressão digital captura um traço fisiológico ('algo que você é'). Como as duas verificações partem de categorias diferentes, o mantrap impõe autenticação multifator genuína — a perda do badge sozinho não abre a porta, e um template de digital roubado também não.

Questão 6: Alternativa D — Uma senha combinada com uma leitura ao vivo da íris do administrador

Somente a opção de senha com leitura de íris combina duas categorias distintas: algo que você sabe e algo que você é. Frases-senha, PINs e respostas a perguntas de segurança são todos segredos baseados em conhecimento, de modo que as outras três opções — por mais perguntas que acumulem — continuam sendo de fator único e falhariam em uma revisão de conformidade de MFA.

Questão 7: Alternativa A — Algo que você faz

Ritmo de digitação, dinâmica do mouse e modo de caminhar são características comportamentais, que mapeiam para o fator 'algo que você faz'. Isso é distinto de 'algo que você é', que se baseia em atributos fisiológicos como impressões digitais, íris ou geometria facial. O sistema autentica como o usuário age, não uma parte do corpo, uma posse ou uma localização.

Questão 8: Alternativa C — Substituir os códigos SMS por códigos TOTP gerados por um aplicativo autenticador instalado no celular de cada funcionário

Os códigos TOTP são calculados localmente pelo aplicativo autenticador a partir de uma semente compartilhada e nunca trafegam pela rede da operadora, de modo que um SIM swap não dá ao invasor nada para interceptar. Aumentar o tamanho do código ou reduzir o tempo de expiração apenas ajusta o mesmo canal frágil de SMS, e a entrega por e-mail apenas troca um canal interceptável e sujeito a redefinição por outro, mantendo o MFA.

Questão 9: Alternativa B — Ativar o number matching, exigindo que o usuário digite o código numérico exibido na tela de login no dispositivo de aprovação

O number matching força o usuário a digitar o valor exibido na tela de login legítima; uma solicitação sem esse código não pode ser concluída, o que elimina toques às cegas e debela ataques de fadiga de MFA (push bombing). Uma

expiração maior apenas dá mais tempo ao atacante, links de aprovação por SMS reintroduzem risco de interceptação e de SIM swap, e pular solicitações em dispositivos confiáveis remove o segundo fator por completo nessas sessões.

Questão 10: Alternativa C — Taxa de aceitação falsa, porque mede com que frequência um indivíduo não autorizado recebe acesso incorretamente

A taxa de aceitação falsa (FAR) quantifica a frequência com que o sistema biométrico aceita um impostor — exatamente o risco de admitir indevidamente alguém não autorizado. A taxa de rejeição falsa (FRR) mede o problema oposto de negar usuários legítimos, a taxa de erro de cruzamento (CER) é o ponto de sensibilidade em que FAR e FRR se cruzam e serve para comparar sistemas em vez de descrever o risco de impostores, e o tempo de cadastro é uma métrica operacional de velocidade sem relação com erros de admissão.